



# Node.js Supply Chain Security + *dhi*

Mohammad-Ali A'râbi





# NPM Made Me Do It!

*It wasn't my code!*

Mohammad-Ali A'râbi







# Mohammad-Ali A'râbi

mohammad-ali@aerabi.com



## Experience

**2024-Now**      **Software Engineer**      JobRad GmbH

- Also a speaker and open-source maintainer
- Creating two more projects/startups

**2023-Now**      **Docker Captain**      Docker, Inc.

- Also a Docker Community Leader since 2022
- Writing Docker blog posts and official documentation

**2023-Now**      **Book Author**      Packt / self

- Writing “Docker and Kubernetes Security”
- The book comes out in October 2025

“Docker Captain, Author of **Docker and Kubernetes Security**, Snyk Ambassador, CNCF Chapter Organizer, Software Engineer, Speaker, Gamer, and DC Comics Fan”



## Social Media and Links

■ **BlueSky**  
■ **GitHub**  
■ **LinkedIn**

■ @aerabi.com  
■ @aerabi  
■ /in/aerabi

■ **Blog**  
■ **Docker Security**  
■ **Medium blog**

■ git-weekly.com  
■ DockerSecurity.io  
■ aerabi.medium.com

■ **Twitter**  
■ **Mastodon**  
■ **Threads**

■ @MohammadAliEN  
■ hachyderm.io/@aerabi  
■ @aerabi.tech

# TL;DR



- I live in **Freiburg**
- Worked at **Berlin** once, @ **Jodel**, doing **Node.js**
- Connect with me on **LinkedIn**
- Flew in today for the meetup





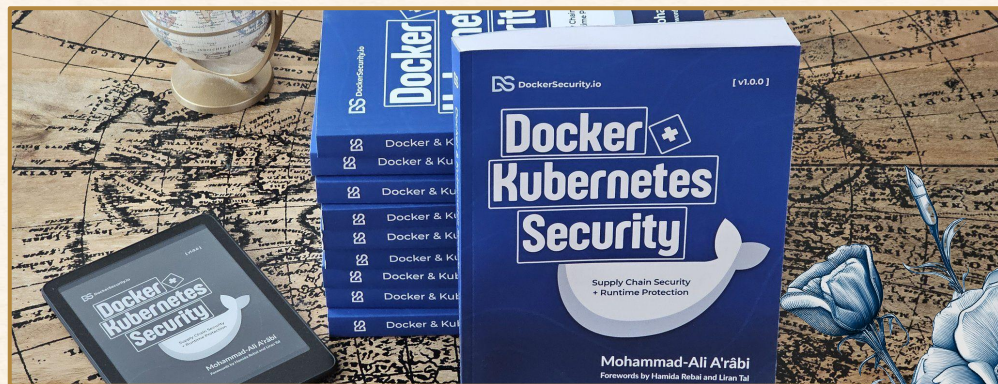
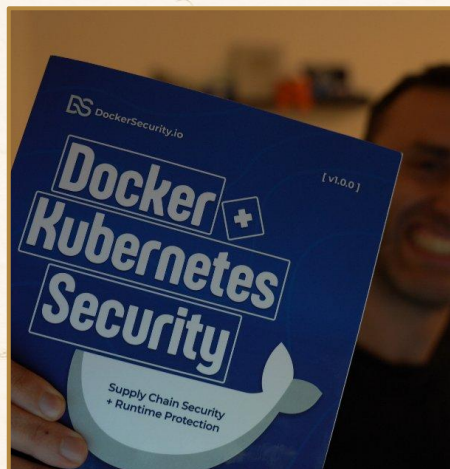
# Docker Captains Summit





# Docker Security.io

Docker and Kubernetes Security  
book is available on:  
**buy.DockerSecurity.io**  
Code for today: **BERNODE25**





# NPM Attack



What happened?

- **Attacker** gained access to a maintainer's account
- Published malicious patch versions of widely-used packages on **NPM**
- The attack was discovered within 2 hours, but there were thousands of downloads before removal
- We were **lucky** this time







# How to Stay Safe

6 ways to be safe from Jack's next attack



# How to Stay Safe

**01** Lock it down

**04** Check libraries

**02** Block lifecycle

**05** Generate SBOMs

**03** Use npq

**06** Harden your base



# oo. Don't overuse

- Third-party packages are huge **commitments**
- Don't do **npm install is-odd**
- Wrap your third-party packages behind internal code
- Have CI jobs that check packages regularly



# 01. Lock it Down

- **Commit** your dependency lock-file
- Never do **npm install** in the CI, use **npm ci**
- Having locked version prevents automatic download of a compromised dependency
- Use **Dependabot** to update in controlled batches





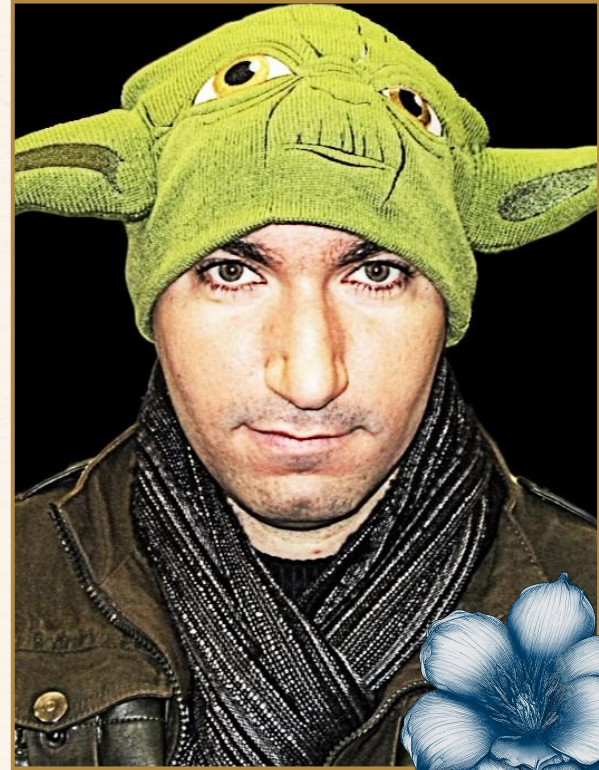
## 02. Block Lifecycle

- Malicious packages often abuse npm lifecycle scripts like **postinstall** to run arbitrary commands.
- Block them by default: **npm install --ignore-scripts**
- Configure CI: **npm config set ignore-scripts true**
- Enable it selectively



## 03. Use npq

- Use **npq** instead of **npm** to install packages
- This tool checks for CVEs and package health
- Basically Snyk Advisor in your terminal
- **npq install chalk**





## 04. Check libraries

- Check your libraries for CVEs
- Use Trivy, Snyk, or Docker Scout
- **docker scout cves jobrad/backend:2.21**
- Check NPM packages as well as OS packages





## 05. Generate SBOMs



- SBOM = **Software Bill of Materials**
- Generate **SBOMs** upon build
- Generate SBOM for all of your Docker stages
- Create SBOM attestations and push them to the repository
- **docker buildx build --sbom=true --push .**





## 05. Generate SBOMs

FROM sapmachine:24-jdk-ubuntu-noble as deps

**ARG BUILDKIT\_SBOM\_SCAN\_STAGE=true**

FROM deps as package

**ARG BUILDKIT\_SBOM\_SCAN\_STAGE=true**



## o6. Harden Your Base

- Use **Docker Hardened Images** as your base
- These images have zero CVEs and are checked continuously by Docker
- **`docker pull org/dhi-node:22`**
- Let's check the CVEs: **demo time**







# Thanks!

**Do you have any questions?**

[linkedin.com/in/aerabi](https://linkedin.com/in/aerabi)

[DockerSecurity.io](https://DockerSecurity.io)



**CREDITS:** This presentation template was created by [Slidesgo](#), and includes icons by [Flaticon](#), and infographics & images by [Freepik](#)

Please keep this slide for attribution

